

Salesforce Org Security Insights

OB Security Assessment Report

Prepared: May 11, 2026

CONFIDENTIAL — For Chief Security Officer Review

Executive Summary

This report presents security findings derived from an automated OB (Org Baseline) analysis of the Salesforce production environment. Four security domains were assessed: Authentication, Authorization, Data Protection, and Integration. The analysis identified **two Critical** and **seven High** severity findings that require prompt remediation. The most urgent issues are the critically low data classification coverage (1.15%) and the broad report/export access granted to 59% of users, both of which present significant data exfiltration risk.

Priority Risk Summary

#	Finding	Domain	Severity
1	Report / Export Access	Authorization	CRITICAL
2	Data Classification Coverage	Data Protection	CRITICAL
3	High-Risk Permission Access	Authorization	HIGH
4	Potential High-Risk Field Candidates	Data Protection	HIGH
5	SSO / MFA Coverage	Authentication	HIGH
6	REST-Exposed Apex Classes	Integration	HIGH
7	Unencrypted Integration Settings	Integration	HIGH
8	Digital Experience Permissions	Authorization	HIGH
9	Stale Users	Authentication	HIGH

1. Authentication

Controls governing how users prove their identity when accessing the org.

Finding	Metric	Severity	Recommendation
SSO / MFA Coverage	48.3%	HIGH	Nearly half of users bypass SSO/MFA and use local username/password. Review local login policies and technically restrict this access to a minimal set of trusted users.
Stale Users	24	HIGH	24 internal users have not logged in for 30+ days. Deactivate per Infosec policy to reduce attack surface.

Finding	Metric	Severity	Recommendation
Non-Compliant Password Policies	3	MEDIUM	3 password policies are misaligned with Infosec standards. Enforce strong policies to protect privileged users who can bypass SSO.
Users Without IP Restrictions	39	MEDIUM	39 users have no IP restrictions. Apply profile-level IP whitelisting, prioritising integration and privileged accounts.

2. Authorization

Controls governing what users can see and do once authenticated.

Finding	Metric	Severity	Recommendation
Digital Experience Sharing	18	HIGH	18 objects/fields exposed in Digital Experiences lack proper sharing configuration. Align record sharing to business and regulatory requirements.
Digital Experience High-Risk Perms	2.02%	HIGH	Experience users hold excess high-risk permissions. Apply Principle of Least Privilege to reduce risk surface.
High-Risk Permission Access	21.1%	HIGH	More than 1 in 5 users hold high-risk permissions. Use Who Sees What Permissions Lens to identify and reduce assignments.
Report / Export Access	59.1%	CRITICAL	59% of users can run or export reports — the primary data-exfiltration avenue for insider threats. Restrict Export Reports and Subscribe to Reports permissions.
Unused Custom Profiles	4	LOW	4 unused custom profiles exist. Remove to eliminate misconfiguration risk.
Vulnerable High-Risk Fields	0	OK	No vulnerable high-risk field access detected.
Objects Open to Deletion	0	OK	No objects unnecessarily open to mass deletion.

3. Data Protection

Controls ensuring sensitive data is classified, restricted, and monitored.

Finding	Metric	Severity	Recommendation
Digital Experience High-Risk Fields	0	OK	No high-risk fields inappropriately exposed via Digital Experiences.
Permission Sets – High-Risk Fields	0	OK	No permission sets grant excess access to high-risk fields.
Profiles – High-Risk Fields	0	OK	No profiles grant excess access to high-risk fields.
Seldom-Used High-Risk Fields	0	OK	No dormant high-risk fields detected.
Potential High-Risk Field Candidates	109	HIGH	109 fields identified as potentially high-risk have not yet been classified. Prioritise classification to enable accurate risk monitoring.
Data Classified	1.15%	CRITICAL	Only 1.15% of data has been classified. Complete classification — especially for high-risk fields — before meaningful data protection analysis is possible.

4. Integration

Controls securing data flows between Salesforce and external systems.

Finding	Metric	Severity	Recommendation
Event Bus Encryption	2	MEDIUM	2 event bus items are unencrypted. If Shield Platform Encryption is licensed, enable 'Encrypt change data capture events and platform events' in Setup → Encryption Policy.
REST-Exposed Apex Classes	5	HIGH	5 Apex classes are exposed via REST. Verify OLS/FLS enforcement (WITH_SECURITY_ENFORCED / Security.stripInaccessible) and 'with sharing' declarations on each class.
Change Data Capture Objects	0	OK	No sensitive data replicated via CDC.
Outbound Messages	0	OK	No insecure outbound message configurations detected.
External High-Risk Fields	0	OK	No high-risk fields sourced from external objects.
Unencrypted Settings	13	HIGH	13 application secrets are stored in Custom Metadata. Migrate to Named Credentials or Custom Settings to prevent exposure.
Insecure Remote Site Settings	1	MEDIUM	1 remote site uses HTTP instead of HTTPS. Enable secure communication where possible.

Recommended Next Steps

Immediate (0–30 days)

1. Launch a Data Classification sprint — classify all 109 high-risk field candidates.
2. Restrict 'Export Reports' and 'Subscribe to Reports' permissions; reduce report access from 59% to role-appropriate levels.
3. Deactivate 24 stale users immediately.

Short-term (30–60 days)

4. Enforce SSO/MFA for the remaining ~52% of non-compliant users; restrict local login to a named admin group.
5. Migrate 13 secrets from Custom Metadata to Named Credentials.
6. Review and reduce high-risk permission assignments (currently 21% of users).

Medium-term (60–90 days)

7. Apply IP restrictions to integration users and other privileged accounts (39 users outstanding).
8. Audit REST-exposed Apex classes (5) for OLS/FLS enforcement and 'with sharing' compliance.
9. Align Digital Experience sharing and permission assignments with Principle of Least Privilege.

This report was generated automatically from live Salesforce org data. Findings should be reviewed in conjunction with your organisation's Infosec policy and applicable regulatory requirements.